

# Menu Registry & Permission-Derived Navigation

Implementation report for the database-backed Menu Registry, server-filtered navigation, SUPERADMIN-only Menu Management UI, and authenticated-but-unauthorized (403) UX.

✓ GREEN – shipped, tested, in scope

19 files changed

1 migration

28 new tests

217 / 225

tests passing (auth + api)

0

regressions introduced

2

new permissions  
justified

9

menu rows seeded

## CONTENTS

- 1

Executive summary
- 2

Architecture implemented
- 3

Files changed
- 4

Database changes
- 5

API changes
- 6

Frontend changes
- 7

Permission behavior
- 8

Menu Management
- 9

Security verification
- 10

Tests / validation
- 11

Known limitations
- 12

Out-of-scope confirmation

## 01 Executive Summary

Implemented exactly what the approved plan authorized: a `Menu` Prisma model (application-scoped, self-referencing tree), a NestJS `MenuModule` serving a permission-filtered nav tree plus SUPERADMIN-only CRUD, two new RBAC permissions

( `menu:manage` , and split `managementDashboard:read` / `customerDashboard:read` so Dashboard is a normal permission-gated leaf, not a special case), a frontend cutover from the static role-array nav to server-fetched navigation, a minimal Menu Management UI, and a real 403 "Access Denied" state distinct from the 401 sign-in redirect.

Existing RBAC ( `UserMembership.role` , `hasPermission` , `CompanyRoleGuard` , `@RequirePermission` , `COMPANY_ID` resolution, G1–G5 lifecycle) was not touched. No `Role→Menu` table, no CRUD-flag-per-menu-row, no second authorization source was created.

## 02 Architecture Implemented

User → UserMembership → **Role** → **Permission** (unchanged)

Menu (DB row, per application)

- └ leaf: `viewResource + viewAction` → `hasPermission(role, resource, action)`
- └ group: visible iff `isActive` AND any child visible

Backend ( `CompanyRoleGuard` + `@RequirePermission` + `hasPermission` ) remains the sole security boundary. `GET /menu/nav` returns an already permission-filtered tree; the client renders it as-is and never re-derives visibility.

### Seeded Management tree (permission → role, current grants)

```
MANAGEMENT └ Dashboard managementDashboard:read └ Leads (group) | └ Messages
lead:read | └ Web Chat chat:read | └ Email (isActive: false) lead:read └ Users
users:read └ Whitelist whitelist:manage └ Menu Management menu:manage new
CUSTOMER └ Dashboard customerDashboard:read TECHNICIAN – no rows seeded; tech-
pwa has no real navigable pages yet
```

## 03 Files Changed

New — backend

| PATH                                                        | WHY                                                                                                           |
|-------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <code>apps/api/src/modules/menu/menu.service.ts</code>      | Tree validation (parenting, ordering, leaf/group consistency) + permission-filtered <code>getNavTree()</code> |
| <code>apps/api/src/modules/menu/menu.controller.ts</code>   | <code>GET /menu/nav</code> (ungated, self-resolving) + SUPERADMIN-only CRUD routes                            |
| <code>apps/api/src/modules/menu/menu.module.ts</code>       | Standard module wiring, mirrors <code>UsersModule</code>                                                      |
| <code>apps/api/src/modules/menu/menu.service.test.ts</code> | 22 service-layer tests against a real Postgres DB                                                             |

New — frontend

| PATH                                                          | WHY                                                        |
|---------------------------------------------------------------|------------------------------------------------------------|
| <code>apps/portal/src/lib/use-nav.ts</code>                   | Fetches the server-filtered nav tree once session is ready |
| <code>apps/portal/src/components/access-denied.tsx</code>     | Shared 403 "Access Denied" state                           |
| <code>apps/portal/src/app/management/menu-management/*</code> | SUPERADMIN-only list / create / edit pages                 |

New — data

| PATH                                                                         | WHY                                                         |
|------------------------------------------------------------------------------|-------------------------------------------------------------|
| <code>packages/db/prisma/migrations/20260819100000_add_menu_registry/</code> | <code>Menu</code> table + <code>MenuApplication</code> enum |
| <code>packages/db/prisma/seed-menu.ts</code>                                 | Idempotent seed mirroring the existing static nav 1:1       |

Modified

| PATH | CHANGE |
|------|--------|
|      |        |

|                                                                                                                                     |                                                                                                                                       |
|-------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| <code>packages/db/prisma/schema.prisma</code>                                                                                       | + <code>Menu</code> model, <code>MenuApplication</code> enum, back-relations on <code>User</code>                                     |
| <code>packages/auth/src/access-control.ts</code>                                                                                    | + <code>menu:manage</code> , <code>managementDashboard:read</code> , <code>customerDashboard:read</code>                              |
| <code>packages/auth/src/index.ts</code>                                                                                             | + additive <code>permissionCatalog</code> export (read-only, for the create/edit form)                                                |
| <code>packages/auth/src/access-control.test.ts</code>                                                                               | + 6 tests for the new grants                                                                                                          |
| <code>apps/api/src/app.module.ts</code>                                                                                             | Registered <code>MenuModule</code>                                                                                                    |
| <code>apps/portal/src/app/management/nav-config.ts</code>                                                                           | Removed static <code>managementNav</code> array + <code>filterNavByRole</code> ; kept <code>NavItem</code> type and pathname helpers  |
| <code>apps/portal/src/app/client/nav-config.ts</code>                                                                               | <b>Deleted</b> — static array no longer has any consumer                                                                              |
| <code>apps/portal/src/app/management/layout.tsx</code> , <code>app/client/layout.tsx</code>                                         | Switched to <code>useNav()</code> ; Forbidden branch now renders <code>&lt;AccessDenied /&gt;</code>                                  |
| <code>users/page.tsx</code> , <code>users/[id]/page.tsx</code> , <code>whitelist/page.tsx</code> , <code>leads/[id]/page.tsx</code> | Added a targeted 403 branch ( <code>isForbidden(err)</code> ) alongside existing error handling — nothing else in these files touched |
| <code>components/management/icons.tsx</code>                                                                                        | + <code>"menu"</code> icon case (reuses existing <code>MenuItemIcon</code> )                                                          |

## 04 Database Changes

One hand-authored migration, `20260819100000_add_menu_registry` : new `MenuApplication` enum ( `MANAGEMENT` , `TECHNICIAN` , `CUSTOMER` ) and `Menu` table — `id` , `application` , `code` , `parentId` , `label` , `href` , `icon` , `order` , `isGroup` , `isActive` , `viewResource` , `viewAction` , `createdByUserId` , `updatedByUserId` , `createdAt` , `updatedAt` . Self-referencing FK on `parentId` ( `onDelete: Restrict` — a parent with children can't be deleted out from under them). `@@unique([application, code])` ; sibling `order` uniqueness is validated in the service layer, not the DB, since Postgres treats `NULL` parent ids as distinct.

No `companyId` / `branchId` on `Menu` — company is deployment-scoped via `COMPANY_ID`, branch doesn't exist anywhere in this schema.

### A pre-existing, unrelated migration hazard was found and routed around

`prisma migrate dev` refused to run non-interactively because it detected an **existing** drift unrelated to this work: `schema.prisma` declares `ChatMessage.seq` as `Int`, but the live column is actually `BIGSERIAL` (confirmed in migration `20260816110344_add_chat_session_message`). Rather than let a generated migration silently fold in an unrelated `BigInt → Integer` cast, the migration SQL was generated via `prisma migrate diff`, the unrelated `ALTER COLUMN "seq"` line was stripped out by hand, and only the `Menu`-related DDL was applied via `migrate deploy`. The `ChatMessage.seq` drift is untouched and still present — it predates this work and is out of scope to fix here.

### Seed

`packages/db/prisma/seed-menu.ts` (idempotent `upsert`, mirrors the existing `seed-contact-topics.ts` convention), run via `pnpm --filter @medcal/db seed:menu`. Seeds exactly what exists today — the 8 Management items 1:1 from the old static array, plus the single Customer Dashboard. No Technician rows: `tech-pwa` has no real navigable pages yet, so there is nothing genuine to seed there.

## 05 API Changes

| ROUTE                                      | GUARD                    | BEHAVIOR                                                                                                                                                                                                    |
|--------------------------------------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>GET /menu/nav?application=</code>    | Session only             | Not <code>@RequirePermission</code> -gated — mirrors <code>MeController</code> 's inline <code>session→membership→ACTIVE</code> resolution. Returns the permission-filtered tree for the caller's own role. |
| <code>GET /menu/permissions-catalog</code> | <code>menu:manage</code> | Read-only catalog listing, for the create/edit form's resource/action dropdowns.                                                                                                                            |
| <code>GET /menu?application=</code>        | <code>menu:manage</code> | Flat admin listing, includes disabled rows.                                                                                                                                                                 |
| <code>GET /menu/:id</code>                 | <code>menu:manage</code> | Single row                                                                                                                                                                                                  |

|                               |                          |                                                                               |
|-------------------------------|--------------------------|-------------------------------------------------------------------------------|
| <code>POST /menu</code>       | <code>menu:manage</code> | Create — full tree/leaf-group validation.                                     |
| <code>PATCH /menu/:id</code>  | <code>menu:manage</code> | Update — same validation, plus circular-parent and leaf-with-children checks. |
| <code>DELETE /menu/:id</code> | <code>menu:manage</code> | Blocked if the row still has children.                                        |

Every route sits behind `CompanyRoleGuard`; routes without `@RequirePermission` pass through it unchecked by design — same opt-in mechanism `MeController` already relies on, not a new pattern.

## 06 Frontend Changes

Both `management/layout.tsx` and `client/layout.tsx` now call `useNav(application, ready)` once the session resolves, instead of filtering a static array by role. `NavItem` lost its `roles` field entirely — filtering already happened server-side, so nothing client-side re-derives it.

**403 UX:** the layout-level "no membership at all" branch now renders `<AccessDenied />` instead of an inline JSX block (cosmetic, same trigger). Four pages with generic catch-all error strings (`users` list/detail, `whitelist`, `leads/[id]`) gained one additional branch: an `ApiError` with `status === 403` now renders `<AccessDenied />` instead of a generic "Gagal memuat..." string. Every other error path in those files — 404, network failures, specific error codes — is untouched.

## 07 Permission Behavior

Exactly two rules, applied recursively over the tree returned by `getNavTree()`:

✓ **Leaf** is visible iff `isActive` and `hasPermission(role, viewResource, viewAction)` is true.

✓ **Group** is visible iff `isActive` and it has at least one visible child — it never carries a permission of its

OWN.

Dashboard follows the exact same two rules — there is no `if (menu === "Dashboard") return true` anywhere. Because the Management-Dashboard role set ( `SUPERADMIN, ADMIN, SUPERVISOR, TECHNICIAN, FINANCE` ) and Customer-Dashboard role set ( `CUSTOMER, SUPERADMIN, ADMIN` ) don't overlap cleanly, two distinct permissions were added rather than collapsing them into one grant that would have silently changed who sees what.

## 08 Menu Management

Gated by the new `menu:manage` permission, currently granted to `SUPERADMIN` only — `ADMIN` is deliberately excluded (matches the locked product decision). Because it's expressed as a normal catalog permission rather than a hardcoded `role === "SUPERADMIN"` check, extending it to `ADMIN` later is a one-line catalog change, not a code change.

UI: a list page grouped by application with inline enable/disable and delete, plus a shared create/edit form (application, code, label, href, icon, parent — scoped to same-application groups only, order, resource/action picked from the live permissions catalog). No drag-and-drop, no generic page builder.

## 09 Security Verification

Menu visibility is a convenience layer, not a trust boundary. Confirmed unchanged and untouched: `UserMembership.role` as role authority, `hasPermission` as the permission authority, `CompanyRoleGuard` + `@RequirePermission` as backend enforcement, `ACTIVE` + membership requirement, server-side `COMPANY_ID` resolution, G1–G5 lifecycle behavior. Hiding a menu item never substitutes for an API check — every existing endpoint keeps returning its existing 403 regardless of what the nav tree shows. Verified live: booted the API, called `GET /menu/nav` and `GET /menu` with no session — both returned 401 before `CompanyRoleGuard` even runs.

## 10 Tests / Validation

- ✓

Auth catalog — 18/18 passing (12 existing + 6 new)  
pnpm --filter @medcal/auth test
- ✓

Menu service — 22/22 passing (leaf/group consistency, code uniqueness, parent validation, circular-parent rejection, ordering, deletion, permission-derived visibility, application isolation)  
pnpm --filter @medcal/api exec vitest run src/modules/menu
- ✓

Full API suite — 199/207 passing; the 8 failures are pre-existing and unrelated ( chat.gateway.security.test.ts ) — confirmed by re-running the identical file with this entire implementation stashed out, which reproduced the same failures  
pnpm --filter @medcal/api test
- ✓

Typecheck — apps/api clean; apps/portal clean except 3 pre-existing, untouched ApiError.data errors  
pnpm --filter @medcal/api typecheck && pnpm --filter @medcal/portal typecheck
- ✓

Build — apps/api clean production build  
pnpm --filter @medcal/api build
- ✓

Runtime boot — Nest app started cleanly, MenuController routes mapped in the correct order ( /menu/nav , /menu/permissions-catalog before /menu/:id ); unauthenticated GET /menu/nav and GET /menu both returned 401
- ✓

Seed — ran twice against the dev DB, second run idempotent (9 rows both times, no duplicates)  
pnpm --filter @medcal/db seed:menu

## 11 Known Limitations

| SEVERITY | GAP                                                                              |
|----------|----------------------------------------------------------------------------------|
| MEDIUM   | apps/portal's next build cannot complete — pre-existing, unrelated ApiError.data |

typecheck errors in `users/[id]/page.tsx` and `users/assign/page.tsx` block it.  
Confirmed present in `HEAD` before this work started; not touched or fixed here (out of authorized scope).

LOW

No HTTP/e2e controller tests for the new routes — matches this repo's existing convention (service-layer tests only, no supertest infra found anywhere in `apps/api`).

LOW

Menu Management form's parent/resource pickers are plain `<select>` elements with no client-side circular-parent preview — the server rejects it, but the UI doesn't pre-empt it.

LOW

`apps/tech-pwa` was not wired to the new nav endpoint — it has no nav/layout structure to integrate with today, and doing so was out of scope.